

# GreenLeaf E-Commerce – Access Control Policy

**Document Owner:** Cameron Naidoo (Interim Security Lead)

**Effective Date:** 26 June 2026

**Review Cycle:** Annually (or immediately upon major breach/regulation change)

**Classification:** Internal / Confidential

**Version:** 1.0

## 1. Purpose

The purpose of this policy is to establish the minimum requirements for authentication and access to GreenLeaf E-Commerce internal systems. This ensures that only authorized individuals can access sensitive company data and infrastructure.

## 2. Scope

This Access Control Policy applies to all **Employees, Contractors, and Third-Party Vendors** accessing internal GreenLeaf systems (e.g., AWS production environment, corporate email, and internal networks).

This policy explicitly excludes customer website accounts, which are governed by a separate Customer Identity and Access Management (CIAM) standard.

## 3. Policy Requirements (Mandates)

To ensure robust protection of internal systems, the following mandatory controls shall be enforced:

- **3.1 Password Construction:** All users must create passwords that meet the complexity and length requirements defined in Section 4 (Standards).
- **3.2 Breach Screening:** All passwords must be screened against known breached password databases upon creation and periodically thereafter.
- **3.3 Multi-Factor Authentication (MFA):** MFA shall be enforced for all access to internal systems. A static password alone is not sufficient for authorization.

## 4. Technical Standards (How to comply)

- 4.1 Password Construction
  - All passwords shall be between **12 and 15 characters** in length.
  - Passwords must include a combination of uppercase and lowercase letters, as well as at least one numeric digit or special character (e.g., !@#\$%^&\*).
  - Common dictionary words, keyboard patterns (e.g., qwerty), and company name variants are explicitly prohibited.
- 4.2 Breach Screening
  - All passwords must be checked against a known breached password database (e.g., HavelBeenPwned API) upon creation and quarterly thereafter.
- 4.3 Multi-Factor Authentication (MFA)
  - MFA (utilizing TOTP, hardware tokens, or biometrics) shall be enforced for all access to internal systems.
  - The default accepted method is the **Google Authenticator** or **Microsoft Authenticator** app on a registered mobile device.

## 5. Procedure (Step-by-Step for New Employees)

"Welcome to the team! Please follow these steps to set up your credentials."

1. **Create Password:** Navigate to the identity management portal (e.g., AWS IAM / Microsoft Entra). Create a password that is 12-15 characters long, including uppercase, lowercase, and a number/special character. Do not use common dictionary words or personal information.
2. **Breach Check:** Upon entering your password, the system will automatically check it against a breached password database. If flagged, you will be prompted to choose a different password. Do not bypass this check.
3. **Enroll MFA:**
  - Download **Google Authenticator** on your mobile device.
  - On your laptop, return to the portal and select "**Set up MFA device**".
  - Scan the QR code displayed on your laptop screen using your phone.
  - Enter the 6-digit code from your phone into the portal to verify the connection.
  - **Final Step:** Log out and log back in using your password AND the authenticator code to confirm MFA is active.

If you encounter any issues, contact the IT Helpdesk immediately. Do not share your MFA codes with anyone.